PHUMULANI

Website Architecture, AI Platform Design and Phase-by-Phase Development Plan

Architectural design, process flows, workflows and development plan for phumulani.org and the connected community platform

Document	Technical architecture and development blueprint
Version	1.0
Date	October 21, 2026
Prepared by	Ophireum Technology
Project	Phumulani Website Development and AI-Assisted Community Platform
Reference site	https://phumulani.org
Primary market	Minnesota, United States
Status	Draft for architecture review. Dates are proposed, not confirmed commitments.

This document defines how the Phumulani website and its connected applications will be designed, built, tested and released. It covers the system architecture, the five applications, the restricted survivor-services boundary, the 18 AI agents, data and security design, all operational workflows, the engineering process and a phase-by-phase plan across a 20-week schedule. Commercial and budget information is intentionally excluded.

Contents

1. Purpose, Scope and Guiding Principles 4
1.1 Purpose 4
1.2 In scope 4
1.3 Out of scope 4
1.4 Architectural principles 4
2. Current-State Assessment of phumulani.org 6
3. Master System Architecture 8
3.1 Technology architecture 8
3.2 Request path 9
3.3 Environments 9
4. Website Information Architecture and Experience Design 10
4.1 Homepage content sequence 10
4.2 Safe-exit and privacy design 11
4.3 Page templates and content model 11
4.4 Accessibility and multilingual design 12
5. Five-Portal Functional Architecture 13
5.1 Role and permission model 13
6. Complete Operational Process Flows and Workflows 15
6.1 Workflow A: Email, AI assistant and communications 15
6.2 Workflow B: Volunteer recruitment and onboarding 16
6.3 Workflow C: Donations and financial reconciliation 18
6.4 Workflow D: Events and community programs 20
6.5 Workflow E: Confidential assistance and safeguarding 22
6.6 Workflow F: Grants, partnerships and board approvals 24
7. AI Workforce and Orchestration Architecture 27
7.1 Agent registry 27
7.2 Per-agent configuration standard 28
7.3 AI safety boundaries 28
7.4 Agent evaluation and release 28
8. Data, API and Integration Architecture 29
8.1 Database domains 29
8.2 Data handling rules 29
8.3 Data classification 29
8.4 API design standards 30

8.5 External integrations 30
9. Security, Privacy and Compliance Design 31
9.1 Required controls 31
9.2 Privacy and legal review 31
9.3 Accessibility 31
10. Complete Development Workflow 32
10.1 Delivery cadence 33
10.2 Source control and branching 33
10.3 CI/CD pipeline 33
10.4 Proposed repository organization 33
10.5 Definition of done 33
11. Phase-by-Phase Development Plan and Design 35
11.1 Schedule overview 35
11.2 Phase 0: Audit and Discovery (Oct 26 - Nov 6, 2026) 36
11.3 Phase 1: Secure Foundation (Nov 9 - Nov 27, 2026) 36
11.4 Phase 2: Website Modernization (Nov 30 - Dec 18, 2026) 37
11.5 Phase 3: Community and Donations (Dec 21, 2026 - Jan 15, 2027) 37
11.6 Phase 4: AI Workforce (Jan 18 - Feb 12, 2027) 38
11.7 Phase 5: Integration and Launch (Feb 15 - Mar 12, 2027) 38
12. Migration, Cutover and Rollback Plan 40
12.1 Rollback triggers 40
13. Quality Assurance and Production Readiness 41
13.1 Test strategy 41
13.2 Production readiness checklist 41
14. Operations, Training and Support Model 43
14.1 Operating model after launch 43
14.2 Training plan 43
15. Governance, Approval Gates, Risks and Decisions 44
15.1 Approval gates 44
15.2 Responsibility matrix (summary) 44
15.3 Key risks and mitigations 44
15.4 Immediate next decisions 45
Appendix A: Glossary 46
Appendix B: Milestone Acceptance Template 47

1. Purpose, Scope and Guiding Principles

1.1 Purpose

Phumulani works with immigrant and refugee survivors of violence in Minnesota. The goal of this programme is to modernize the public website and add secure, connected tools that strengthen fundraising, volunteer recruitment, community engagement and daily administration, while protecting the confidentiality that the mission requires.

1.2 In scope

- Public website and content management system (CMS) at phumulani.org, including multilingual content, accessibility and search optimization.
- Four authenticated applications: Community and Volunteer Hub, Donor and Sponsor Portal, Staff Command Center, and Executive and Governance Portal.
- A separate, restricted survivor-services environment with its own security boundary.
- An AI workforce of 18 specialized agents operating through a central control layer with human approval gates.
- Shared services: identity, workflow and approvals, CRM, events, donations ledger, communications, analytics, audit and notifications.
- Engineering process, environments, CI/CD, testing, security, migration, training and operational handover.

1.3 Out of scope

- Budget, pricing and commercial terms (removed from this document by request).
- Legal opinions. Counsel must review Minnesota and federal privacy, survivor-confidentiality and nonprofit obligations before production use.
- Clinical, counseling or case-management decision-making. These remain human responsibilities.

1.4 Architectural principles

Principle	What it means in practice
Protect survivors first	Survivor data lives in an isolated boundary. No public portal, general CRM, analytics set or general-purpose AI can reach it.
Humans decide	AI drafts, classifies and summarizes. People approve outbound messages, financial actions, volunteer screening, safeguarding and governance decisions.
Preserve before replacing	The existing donation pathway and survivor-support resources stay live until replacements pass reconciliation and acceptance testing.
API-first and modular	Each portal has its own experience and authorization boundary; shared services provide consistent identity, workflow and reporting.
Deny by default	Every role, tool and data path is explicitly granted. Nothing is open because it was convenient.

Principle	What it means in practice
Least data	Personal information is collected only for a defined purpose; AI agents see minimized, authorized datasets only.
Accessible and mobile-first	WCAG 2.2 AA is a release gate. Plain language, low-bandwidth friendly and usable on shared or older phones.
Auditable	Approvals, state changes and sensitive reads are logged with actor, decision and timestamp.

2. Current-State Assessment of phumulani.org

The following was observed on the live homepage on October 21, 2026. It is a starting inventory only; the Phase 0 audit will confirm it in depth (plugins, theme, hosting, backups, analytics, forms and content ownership).

Area	Observation	Architectural implication
Platform	Built on WordPress; the homepage uses the Slider Revolution plugin.	Audit versions, plugin health and security posture before deciding to retain or replace the CMS.
Navigation	Home, Programs, Board and Staff, Get Involved, Support Us, Contact.	Preserve these top-level destinations and URLs; add redirects for any path that changes.
Giving	Support Us and Donate Now link to a hosted PayPal donation button.	Keep PayPal live as the fallback until the new payment flow passes reconciliation testing.
Mission content	Mission, vision, financial empowerment commitment, founder story (Comfort Dondo) and core areas.	Migrate as approved content; the founder story and impact report need owner sign-off before reuse.
Impact reporting	The 2025 Impact Report is published as a PDF.	Provide an accessible HTML impact page alongside the PDF; keep the PDF at its existing URL.
Publications	Books listed: Facing the Giants, Sacred Promise, and The Gift in Pain (coming soon).	Add a Publications content type with status (available, coming soon).
Get Help	Links to direct services, individual counseling, relief and referrals, plus housing, legal, childcare, healing, education, employment and benefits.	Rebuild as a discreet Get Help hub with a safe-exit control and safe routing into the restricted boundary.
Contact and social	A phone line, contact page and LinkedIn, Facebook, Instagram and X links.	Add a privacy notice to the phone and form entries; confirm which channels are safe to publish.
Imagery	Event photo gallery on the homepage.	Introduce a consent register for photos, stories and testimonials.

Approval Gate G0: retain or replace the CMS

The Phase 0 audit decides whether WordPress is hardened and kept for the public site (Option A), or the public site is rebuilt on Next.js (Option B). Both options share the same portals, services and security architecture; only the public front end differs.

Criterion	Option A: retain and harden WordPress	Option B: rebuild on Next.js
Speed to launch	Faster; content and URLs largely preserved.	Slower; full content migration required.
Editor experience	Familiar to current staff.	New CMS or headless editor to learn.

Criterion	Option A: retain and harden WordPress	Option B: rebuild on Next.js
Security surface	Depends on plugin hygiene; needs strict update and WAF policy.	Smaller surface; code under version control and CI.
Integration with portals	Via REST and single sign-on bridge.	Native shared design system and authentication.
Best when	Audit finds healthy core, supported theme and manageable plugins.	Audit finds unsupported plugins, poor performance or accessibility that cannot be remediated.

3. Master System Architecture

The platform is modular and API-first. Five applications sit behind an edge layer and an API gateway; shared domain services and data stores support them. The restricted survivor-services boundary is separate and is reachable only through a narrow, audited routing path.

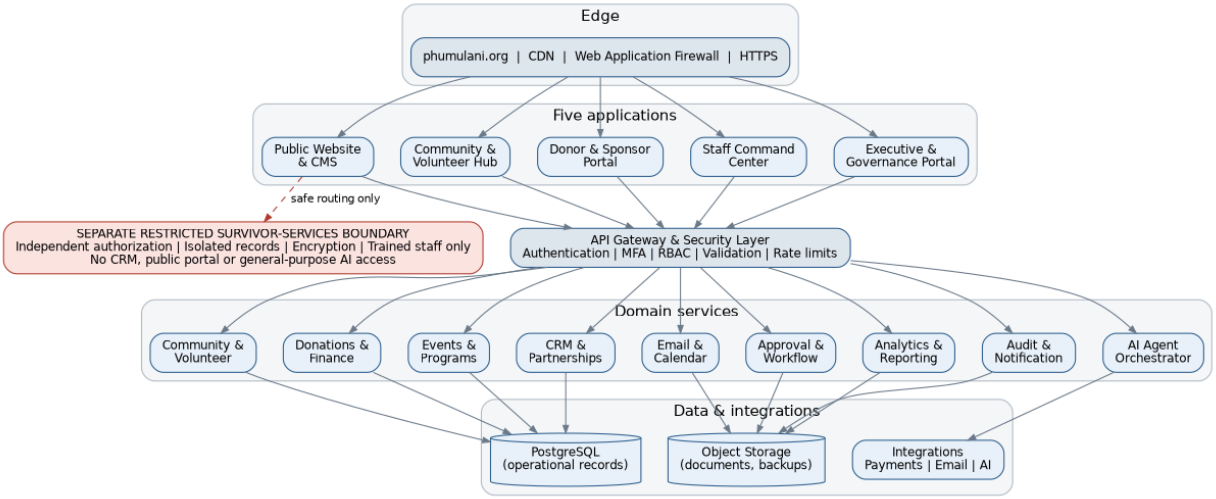


Figure 1. Logical system architecture. Physical cloud resources are finalized after Phase 0.

3.1 Technology architecture

Layer	Recommended technology	Responsibility
Public website	WordPress (if audit-approved) or Next.js	Content, accessibility, SEO, forms
Portal frontend	Next.js, React, TypeScript	Secure role-based dashboards
Design system	Tailwind CSS and reusable accessible components	Consistent responsive interface across all portals
Backend	TypeScript API services	Business logic, validation, orchestration
Database	PostgreSQL with row-level security	Structured operational records
Background processing	Durable job queue and workers	Retries, reminders, webhooks, scheduled jobs
Authentication	OIDC-compatible identity provider	MFA, sessions, single sign-on, permissions
AI	LLM API with controlled tool access	Drafting, classification, summarization, assistance
Email and calendar	Google Workspace or Microsoft 365	Shared inboxes and schedules
Donations	Approved hosted payment provider	Payments, recurring giving, receipts
Infrastructure	Managed cloud, CDN, WAF, infrastructure as code	Deployment, scaling and protection

Layer	Recommended technology	Responsibility
Observability	Central logs, metrics, traces and alerts	Operational oversight and incident response

3.2 Request path

1. A visitor or user reaches phumulani.org through the CDN and web application firewall over HTTPS.
2. Public pages are served from the CMS; authenticated areas redirect to the identity provider for sign-in and MFA.
3. Every API call passes the gateway: token validation, role check, input validation and rate limiting.
4. The gateway routes to the owning domain service, which reads or writes only its own database domain.
5. State changes emit audit events and, where required, create an approval task in the workflow engine.
6. Background workers handle email, reminders, payment webhooks and AI jobs with retries and dead-letter handling.

3.3 Environments

Environment	Purpose	Data rule
Local	Developer machines and containers	Synthetic data only
Development	Integration of merged work	Synthetic data only
Staging	Production-like acceptance, security and load testing, AI evaluation	Synthetic or fully anonymized data only
Production	Live service	Real data; change-controlled; monitored
Restricted production	Survivor-services application and database	Separate account, network, keys, deployment pipeline and access reviews

4. Website Information Architecture and Experience Design

The public site stays welcoming, simple and mobile-friendly. Administrative functions stay behind authentication so the public navigation is never crowded.



Figure 2. Public site map and primary navigation.

4.1 Homepage content sequence

#	Section	Content
1	Hero	Mission statement, plain-language message, clear Get Involved and Donate calls to action.
2	Who We Are	Mission, vision, founder story and organizational background.
3	Programs	Six program categories linking to dedicated detail pages.
4	Get Involved	Volunteer, mentorship, youth leadership and board opportunities.
5	Impact	Approved aggregate outcomes, testimonials and stories shared with informed consent; link to the Impact Report.

#	Section	Content
6	Campaigns	Current fundraising and sponsorship initiatives.
7	News and Events	Upcoming activities and approved announcements.
8	Support and Contact	Discreet channels, privacy and safety information.

4.2 Safe-exit and privacy design

- A persistent Safe Exit control on sensitive pages (Get Help, support resources): one click or key press opens a neutral site and replaces the current page in browser history.
- Clear wording that Safe Exit cannot erase browsing history or guarantee safety on a monitored device, with short guidance on safer browsing.
- No third-party tracking scripts or advertising pixels on Get Help pages; analytics on those pages are aggregate and cookieless.
- Contact forms on sensitive pages collect minimum fields, state how the information is used, and route to the restricted intake endpoint, never to the general inbox.
- Discreet page titles, no sensitive terms in URLs, and no auto-filled or autosaved form data on sensitive forms.

4.3 Page templates and content model

Template	Used for	Key fields
Landing	Home, Get Involved, Donate	Hero, calls to action, sections, featured content
Program detail	Six program pages	Summary, eligibility (public wording), how to access, related resources, safe contact route
Opportunity	Volunteer, board, youth council, mentorship	Role, time commitment, requirements, language, apply action
Campaign	Fundraising and sponsorship	Goal text, story, giving options, sponsor tiers, impact statement
Event	Events and workshops	Date, location or link, capacity, registration, accessibility notes
Story / News	Updates and approved stories	Body, media, consent status, publication approval
Resource	Resource directory	Category, language, region, verified date, owner
Team	Board and Staff	Name, role, biography, photo consent
Publication	Books and materials	Title, status (available or coming soon), purchase or info link
Help	Get Help hub	Service description, discreet contact route, safe-exit enabled

4.4 Accessibility and multilingual design

- WCAG 2.2 AA target: keyboard navigation, visible focus, sufficient contrast, labeled forms, accessible error messages, captions and alt text.
- Plain-language review of all public content; reading level targeted for broad community use.
- Multilingual framework: language switcher, translated slugs, right-to-left readiness and translation workflow. AI translation is used only for non-sensitive content and is reviewed by a human before publishing.
- Performance budget for low-bandwidth and older mobile devices: optimized images, lazy loading and minimal client-side scripting on public pages.

5. Five-Portal Functional Architecture

Each portal uses a consistent interface: collapsible left navigation, a simple top bar, role-specific dashboards, contextual actions and no unnecessary controls. All portals share one identity service and one design system.

Portal	Primary users	Core modules	Key controls
A. Community and Volunteer Hub	Volunteers, members, mentors, youth council	Applications, screening status, approved opportunities, event registration, orientation and training, mentorship matching, learning materials, volunteer hours, feedback	Staff retain screening and placement decisions; permission-based access to materials; safeguarding acknowledgments
B. Donor and Sponsor Portal	Donors, sponsors	Donation history, recurring gifts, receipts, campaign sponsorship, acknowledgments, downloadable records, aggregate impact reports	Donors see only their own records; card data never stored on platform; provider-hosted checkout
C. Staff Command Center	Employees, coordinators	Shared inbox, CRM, volunteer screening queue, events and programs, calendars, AI draft review, task assignment, grant tracking, communications, operational analytics	Role-based modules; approval queue for all AI outputs; MFA required
D. Executive and Governance Portal	Executives, board	Executive summaries, approved financial aggregates, budgets and grants view, board documents, agendas, resolutions, approval register, risk oversight, organization-wide KPIs	Read-mostly; aggregates only; no survivor-level data; phishing-resistant authentication for administrators
E. Public Website and CMS	Public visitors, content editors	Programs, events, news, campaigns, volunteering, resources, public forms, safe service routing, multilingual content, SEO	Editorial workflow with draft, review and publish roles; forms cannot write privileged records

Restricted survivor-services environment

This is a separate security boundary, not an ordinary sixth portal. It has independent authorization, isolated records, its own encryption keys, trained-staff-only access, and no connection to the general CRM, analytics datasets, public portal or general-purpose AI. Its design and activation require review and sign-off by Phumulani's safeguarding lead.

5.1 Role and permission model

Role	Typical access	Not permitted
Visitor	Public pages, public forms	Any authenticated data
Volunteer / member	Own profile, applications, hours, assigned opportunities and learning content	Other users' data, donor data

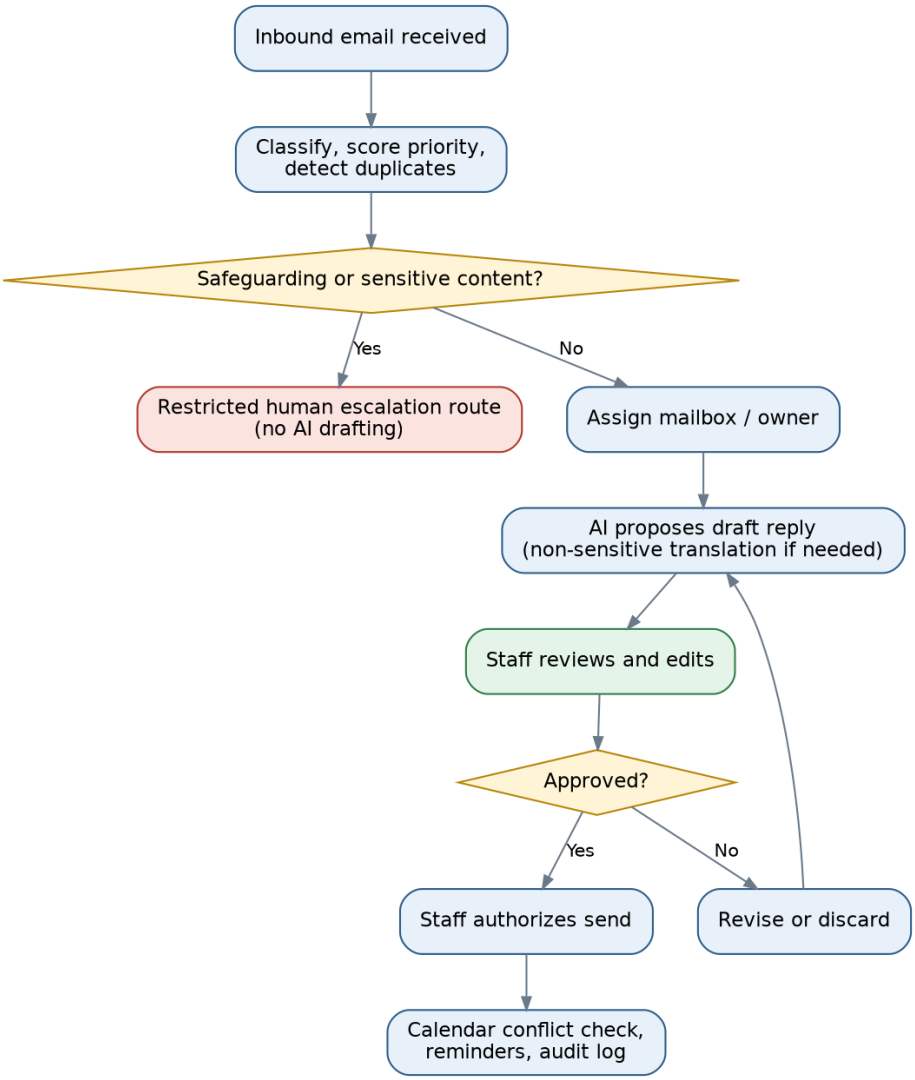
Role	Typical access	Not permitted
Donor / sponsor	Own gifts, receipts, sponsorship records	Other donors, volunteer data
Staff (by function)	Modules for their function: community, events, finance, communications	Restricted survivor records; modules outside their function
Finance staff	Reconciliation, ledger review, receipts	Changing verified payment records without dual approval
Executive	Aggregate dashboards, approvals, grants and board materials	Individual-level sensitive records
Board member	Board documents, agendas, resolutions, oversight dashboards	Operational records
Administrator	User and role administration, configuration	Business approvals; reading restricted records
Safeguarding officer	Restricted environment (trained and authorized only)	Export to other systems

6. Complete Operational Process Flows and Workflows

Each workflow below shows where automation operates and where a human must decide. Colour key: blue = system or AI step; green = human review or approval; amber = decision; red = restricted or safeguarding step.

6.1 Workflow A: Email, AI assistant and communications

Inbound correspondence is classified and drafted for staff review. Safeguarding or sensitive content never enters the AI drafting path.



Step detail

1. Email arrives in a shared mailbox and is referenced (not copied wholesale) in the platform.
2. The Email Manager agent classifies it, scores priority, detects duplicates and checks for sensitive indicators.

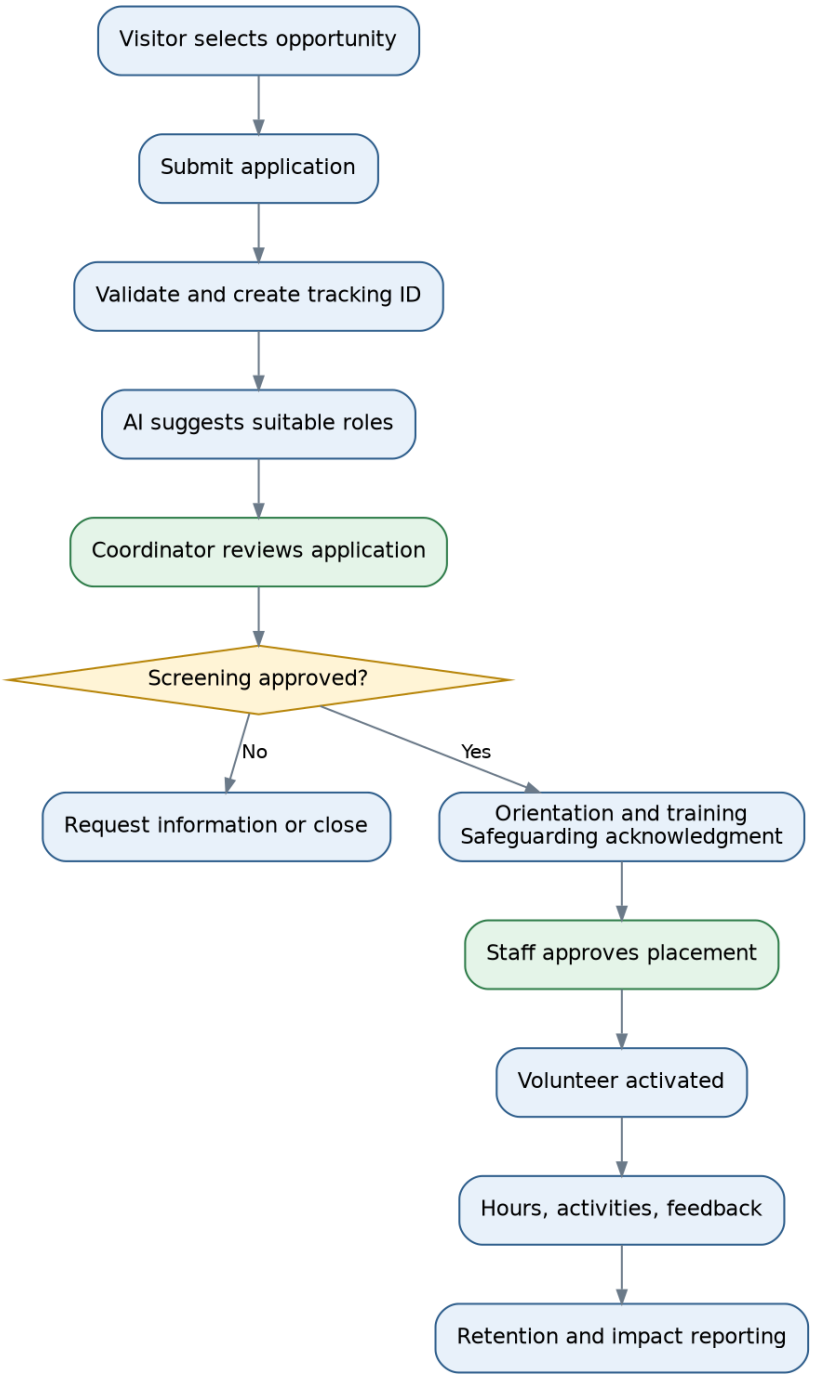
3. Sensitive or safeguarding content is routed to a restricted human escalation queue and AI processing stops.
4. Otherwise a mailbox owner is assigned and the agent proposes a draft; non-sensitive correspondence can be translated.
5. Staff review, edit and approve; the Calendar Manager checks conflicts for any proposed meeting.
6. Staff authorize the send; reminders and follow-ups are scheduled and every step is logged.

Control rules

- Outbound messages always require staff authorization.
- Priority scoring, mailbox assignment, duplicate detection, reminders and calendar conflict checks are supported.
- Drafts store the prompt version, model and reviewer for audit.

6.2 Workflow B: Volunteer recruitment and onboarding

Applicants move from interest to active volunteer through coordinator screening, training and staff placement approval.



Step detail

1. Visitor selects an opportunity and submits an application on the public site.
2. The system validates the form and creates a tracking ID with a confirmation message.
3. The Volunteer Recruiter agent suggests suitable roles from stated skills, availability and language.
4. A coordinator reviews the application and completes screening, including references where required.

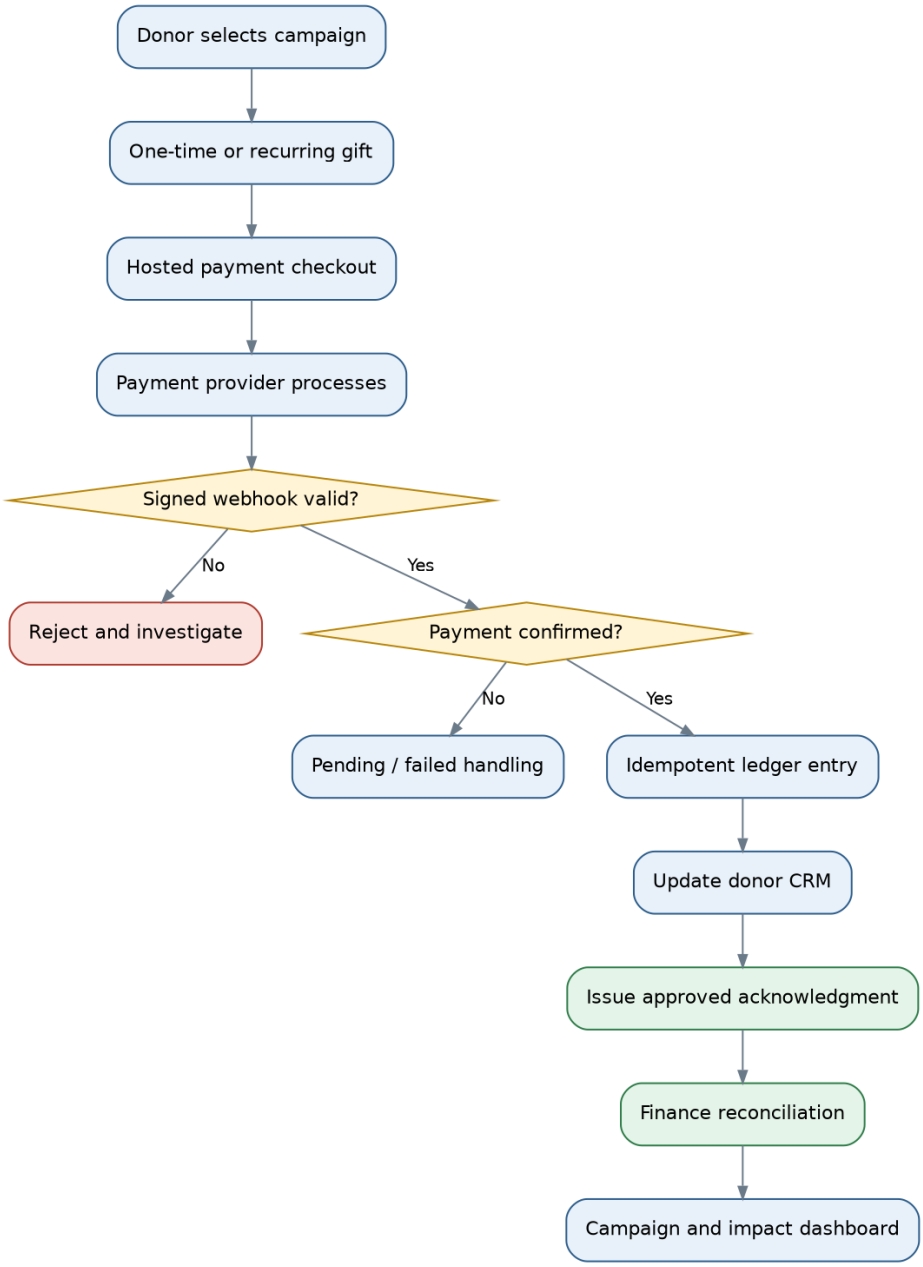
5. If screening is not approved, the applicant is asked for more information or the file is closed with a respectful message.
6. Approved applicants complete orientation, training and safeguarding acknowledgments.
7. Staff approve placement; the volunteer is activated and gains permission-based access.
8. Hours, activities and feedback are recorded; retention and impact are reported in aggregate.

Control rules

- Staff keep responsibility for screening and placement.
- Language preference, availability, skills and training status are first-class fields.
- Access to materials and events depends on completed requirements.

6.3 Workflow C: Donations and financial reconciliation

Only verified payment-provider events update the financial ledger.



Step detail

1. Donor chooses a campaign and a one-time or recurring gift.
2. The donor completes payment on the provider's hosted checkout; card details never touch Phumulani systems.
3. The provider confirms the transaction and sends a signed webhook.
4. The platform verifies the signature; invalid events are rejected and investigated.
5. Confirmed payments create an idempotent ledger entry; pending or failed payments follow a retry and notification path.
6. The donor record and campaign totals update; an approved acknowledgment and receipt are issued.

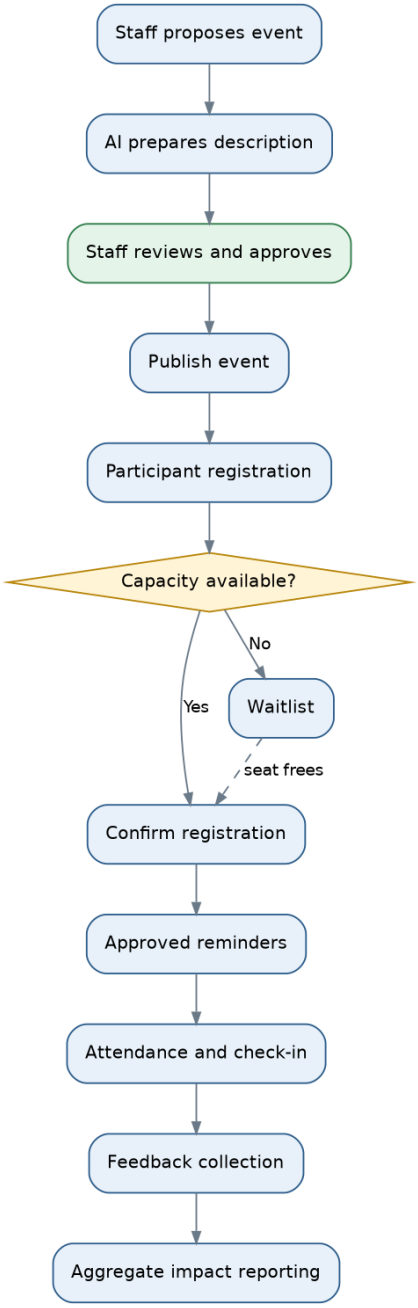
7. Finance reconciles ledger entries to provider and bank statements; the dashboard reflects reconciled totals.

Control rules

- Refunds, bank-detail changes and unusual financial exceptions remain human-controlled.
- Duplicate webhook deliveries cannot create duplicate gifts (idempotency keys).
- The existing PayPal pathway stays operational until reconciliation testing is passed.

6.4 Workflow D: Events and community programs

Events are drafted with AI assistance but published only after staff approval; capacity is enforced by the system.



Step detail

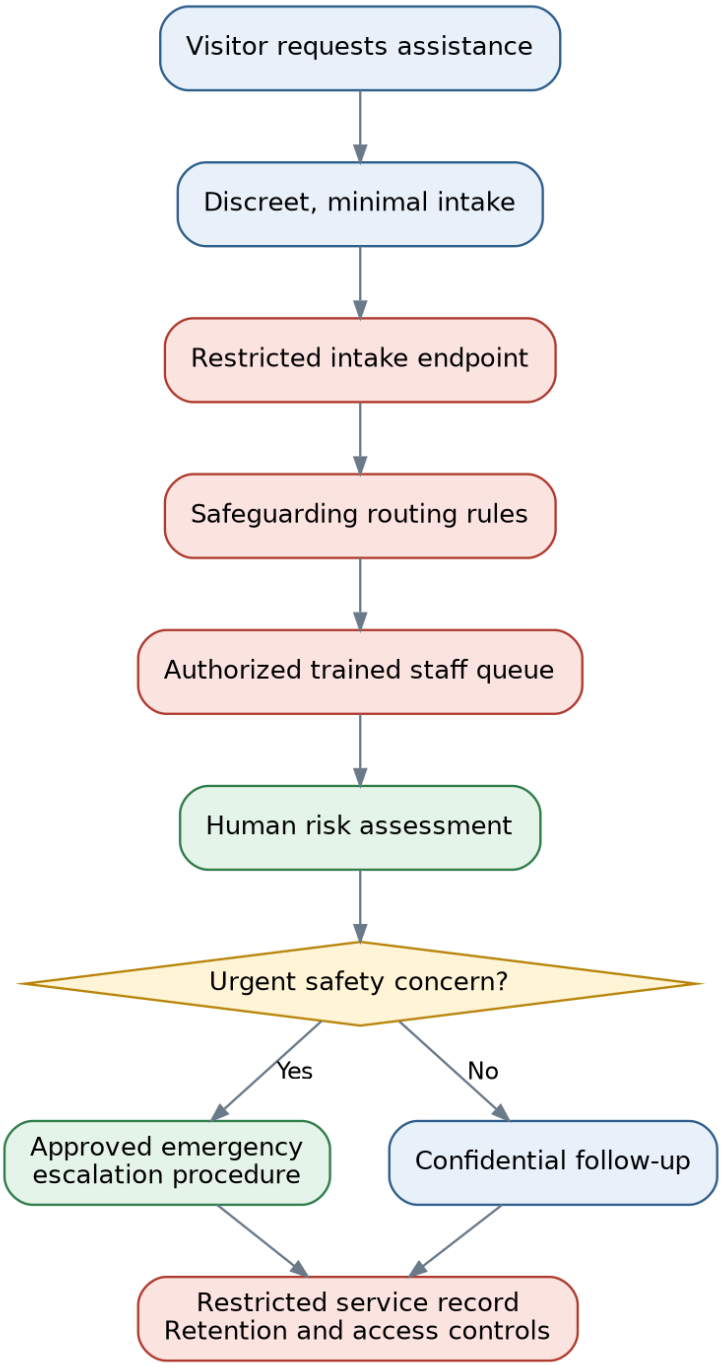
1. Staff propose an event with date, venue or link, capacity and accessibility details.
2. The Events Coordinator agent drafts the description and registration questions.
3. Staff review and approve; the event is published to the website and Community Hub.
4. Participants register; the system checks live capacity.
5. If full, participants join a waitlist and are promoted automatically when a seat frees.
6. Approved reminders go out; check-in records attendance on the day.
7. Feedback is collected and summarized into aggregate impact reporting.

Control rules

- Registrations can never exceed capacity (tested as a release gate).
- Reminders and announcements use approved templates.

6.5 Workflow E: Confidential assistance and safeguarding

The most sensitive workflow. It is human-led, isolated, and must be approved by the safeguarding lead before activation.



Step detail

1. A visitor requests help through a discreet, minimal-data form or contact route.
2. The request goes to a restricted intake endpoint, not the general website database or inbox.
3. Routing rules direct the request to the authorized trained staff queue.
4. A trained staff member performs the human risk assessment.
5. If there is an urgent safety concern, the approved emergency escalation procedure is followed.
6. Otherwise confidential follow-up proceeds through approved channels.

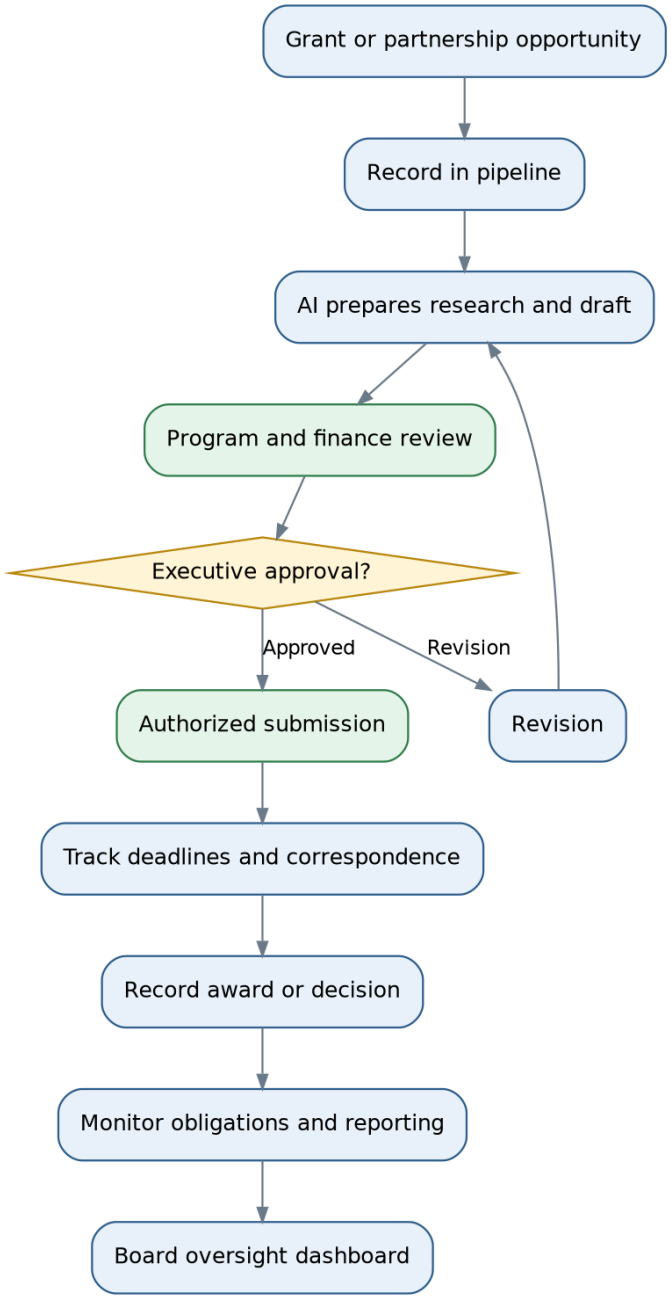
7. Records are stored in the restricted service record under defined retention and access controls.

Control rules

- General AI agents must not assess danger, decide eligibility, disclose case histories or send sensitive messages automatically.
- The Privacy and Safeguarding agent may only send redacted policy alerts to human officers.
- Survivor records are never copied into the CRM, analytics datasets or AI knowledge bases.

6.6 Workflow F: Grants, partnerships and board approvals

Opportunities move through research, review, executive approval, submission and ongoing obligation tracking.



Step detail

1. An opportunity is recorded in the grants and partnerships pipeline.
2. The Grants Assistant researches fit and drafts content using approved organizational materials.
3. Program and finance staff review accuracy, budgets and commitments.
4. Executive approval is required; revisions loop back to drafting.
5. An authorized person submits; deadlines and correspondence are tracked.
6. The award or decision is recorded, and obligations and reporting dates are monitored.
7. Results feed the board oversight dashboard and approval register.

Control rules

- No submission or partnership commitment without recorded executive approval.
- The Board Secretary agent produces agendas, minutes drafts and action registers for human review.

7. AI Workforce and Orchestration Architecture

The 18 agents operate through a centralized AI Command Center. They never access sensitive systems directly; every tool call passes the Policy and Approval Gateway.

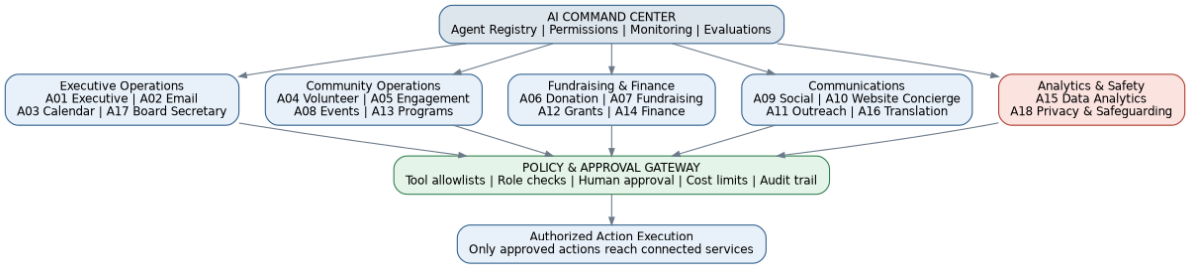


Figure 3. AI Command Center and policy gateway.

7.1 Agent registry

ID	Agent	Primary responsibility	Human control
A01	Executive Assistant	Priorities, tasks and executive summaries	Executive reviews
A02	Email Manager	Inbox classification and response drafts	Staff approves every send
A03	Calendar Manager	Availability and scheduling proposals	Owner confirms invitations
A04	Volunteer Recruiter	Application classification and role matching	Coordinator screens and approves
A05	Community Engagement	Activities and moderated content	Staff moderator approves posts
A06	Donation Manager	Donation reconciliation assistance	Finance confirms
A07	Fundraising Strategist	Campaign drafts and forecasts	Executive approves campaigns
A08	Events Coordinator	Events and registration assistance	Staff approves publication
A09	Social Media Manager	Content drafts and publishing queue	Communications lead approves
A10	Website Concierge	Answers from approved public FAQs only	Content owner maintains source
A11	Outreach Coordinator	Partnership and follow-up drafts	Staff approves outreach
A12	Grants Assistant	Grant pipeline and proposal drafting	Executive approves submission
A13	Program Coordinator	Administrative routing only	No eligibility or case decisions
A14	Finance Assistant	Reconciled financial summaries	Finance lead reviews
A15	Data Analytics	KPI validation and anomaly detection	Analyst reviews findings
A16	Translation Assistant	Non-sensitive multilingual content	Bilingual reviewer approves
A17	Board Secretary	Agendas, minutes and action registers	Board chair or secretary approves
A18	Privacy and Safeguarding	Redacted policy alerts to human officers	Officers decide all actions

7.2 Per-agent configuration standard

Every agent is delivered as a controlled package with the following elements. An agent without all of them cannot be enabled.

- **Permissions:** allowlisted tools, data scopes and roles, reviewed and versioned.
- **Versioned instructions:** system prompt, policies and templates under source control with change history.
- **Test dataset and evaluations:** synthetic scenarios covering normal, edge and adversarial cases with pass thresholds.
- **Usage limits:** per-agent and organization-wide caps on calls and tokens, with alerts.
- **Escalation rules:** conditions that stop the agent and route to a named human.
- **Disable control:** an administrator can pause any agent or all agents immediately.
- **Audit trail:** every run records inputs referenced, tools called, outputs, reviewer and decision.

7.3 AI safety boundaries

- AI assists people; it does not replace judgment in safeguarding, financial authorization, volunteer screening or governance.
- Agents receive minimized, redacted data and cannot browse the database freely.
- No agent can send external communications, move money, change bank details, approve volunteers or alter permissions.
- Retrieval for the Website Concierge is limited to a curated public knowledge base.
- Prompt-injection defenses: untrusted content (emails, forms, documents) is treated as data, tool calls are validated against policy, and high-impact actions require approval regardless of model output.
- Agents run in a simulation environment first; production activation is progressive and one agent at a time.

7.4 Agent evaluation and release

1. Define the task, allowed tools and refusal behaviours.
2. Build a synthetic test set including sensitive-content, injection and misuse cases.
3. Run evaluations; record accuracy, refusal correctness, leakage and approval-bypass attempts.
4. Pass milestone M4 criteria; the safeguarding lead reviews agents that touch sensitive paths.
5. Enable in shadow mode (outputs visible to staff, nothing actioned), then supervised production, then normal operation.
6. Re-evaluate after every prompt, model or tool change and on a regular schedule.

8. Data, API and Integration Architecture

8.1 Database domains

Domain	Principal records
Identity	Users, roles, sessions, permissions
Community	Members, volunteers, applications, skills, availability, hours
Programs	Programs, opportunities, enrollments
Events	Events, registrations, waitlists, attendance
Fundraising	Donors, campaigns, transactions, receipts
CRM	Organizations, contacts, interactions, partnerships
Communications	Mail references, drafts, templates, approvals
Governance	Board meetings, grants, resolutions, reports
AI Control	Agents, versions, runs, evaluations, tool permissions
Operations	Tasks, notifications, workflow states
Audit	Events, actors, decisions, timestamps
Restricted Services	Separate survivor intake and case records (own database and keys)

8.2 Data handling rules

- Every record receives a unique identifier and creation timestamp.
- Personal information is collected only when needed for a defined purpose.
- Public forms cannot write directly to privileged records; they write to a validated intake queue.
- AI agents access only explicitly authorized, minimized datasets.
- Financial events use verified provider identifiers and idempotency checks.
- Audit events record approvals and state changes and cannot be edited by application users.
- Restricted survivor records must not be copied into ordinary CRM tables, analytics datasets or general AI knowledge bases.
- Retention and deletion schedules are defined per domain and enforced by scheduled jobs.

8.3 Data classification

Level	Class	Examples	Handling
01	Public	Approved pages, public events, campaigns	Published through CMS; cacheable
02	Internal	Operational tasks, staff communications	Authenticated staff; logged

Level	Class	Examples	Handling
03	Confidential	Donor information, volunteer applications, protected organizational documents	Encrypted; role-based; AI access minimized
04	Highly Restricted	Survivor identities, case information, safety plans	Isolated environment; independent access; no AI general access

8.4 API design standards

- Versioned REST APIs with a shared contract package (typed schemas) used by front ends and services.
- Schema validation on every request and response; consistent error format; no sensitive data in error messages.
- Pagination, filtering and rate limits on all list endpoints; idempotency keys on all state-changing financial and registration calls.
- Service-to-service calls authenticated with short-lived credentials; no shared database access between services.
- Webhooks (payments, email) verified by signature, timestamped and replay-protected.

8.5 External integrations

Integration	Direction	Notes
Payment provider	Two-way	Hosted checkout; signed webhooks; refunds handled by finance staff
Email and calendar suite	Two-way	Shared inboxes and calendars; reference, do not duplicate, message content
AI model API	Outbound	Via orchestrator only; redacted inputs; usage-limited
Identity provider	Two-way	OIDC single sign-on, MFA, role claims
Analytics (privacy-respecting)	Outbound	Aggregate, cookieless on sensitive pages
Backup storage	Outbound	Encrypted, verified restores

9. Security, Privacy and Compliance Design

9.1 Required controls

Control area	Requirement
Authentication	Staff MFA; phishing-resistant authentication (for example security keys) for administrators; session timeouts and device checks.
Authorization	Deny by default; role-based access with row-level policies; periodic access reviews.
Data protection	Encryption in transit and at rest; managed secrets and key rotation; separate keys for the restricted environment.
Application security	Input validation, output encoding, CSRF and clickjacking protection, secure headers, dependency and secret scanning.
Payment security	Provider-hosted checkout; signed webhooks; no card data stored.
Network	CDN and WAF, rate limiting, private networking for databases and services.
Monitoring	Central logging, alerting on anomalous access, failed logins and approval bypass attempts.
Resilience	Automated encrypted backups, verified restoration, rollback procedures and recovery drills.
Testing	Vulnerability scans in CI, penetration test before launch, adversarial tests against the restricted boundary.
Incident response	Documented plan, roles, contact tree, breach-notification review with counsel, post-incident review.
Vendor management	Review of providers' security and data terms; data-processing agreements where required.

9.2 Privacy and legal review

- Counsel reviews applicable Minnesota and federal privacy, survivor-confidentiality and nonprofit obligations before production use.
- Privacy notice, cookie notice and consent language written in plain language and available in key community languages.
- Consent register for photos, stories and testimonials with withdrawal handling.
- Data-subject request procedure (access, correction, deletion) with defined owners.

9.3 Accessibility

WCAG 2.2 AA is verified with automated tools, manual keyboard and screen-reader testing, and review by users where possible. Accessibility defects at A or AA level block release.

10. Complete Development Workflow

This is the engineering process from discovery to deployment. Every phase of the plan in Section 11 runs this lifecycle at its own scale.

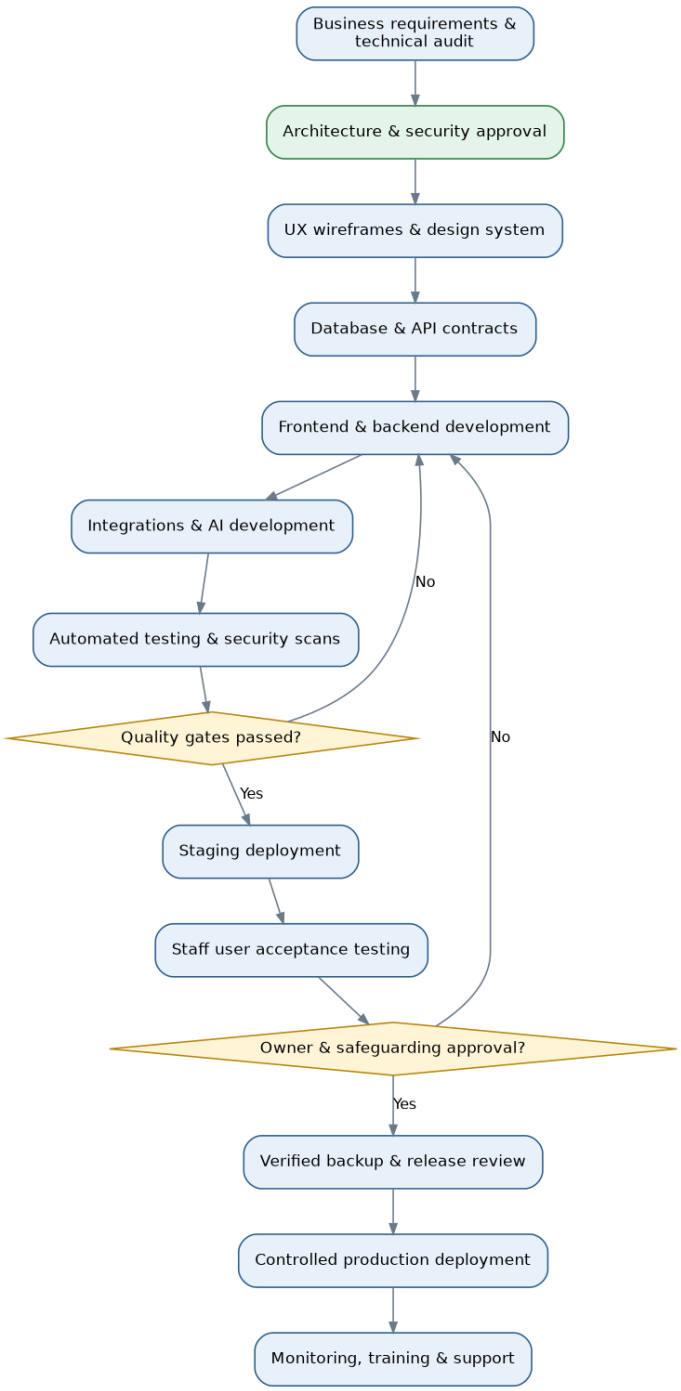


Figure 4. End-to-end development lifecycle with quality and approval gates.

10.1 Delivery cadence

- One-week iterations inside each phase; a demo and a short written status at the end of each week.
- Backlog owned by the Phumulani product owner; priorities confirmed at the start of each phase.
- Each phase closes with a milestone review (M0 to M5) and written acceptance before the next phase is released.
- Change requests are logged, assessed for scope and schedule impact, and approved by the owner before work begins.

10.2 Source control and branching

- Trunk-based development with short-lived feature branches; protected main branch.
- Pull requests need at least one peer review, passing checks and linked work item.
- Conventional commit messages and automatic changelog generation.
- Database migrations are versioned, reviewed and tested against a copy of staging schema.

10.3 CI/CD pipeline

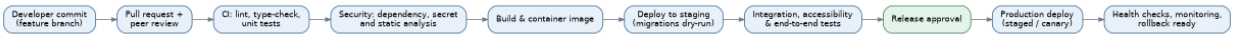


Figure 5. Continuous integration and delivery pipeline.

10.4 Proposed repository organization

```
phumulani-platform/
  apps/
    public-web/
    community-portal/
    donor-portal/
    staff-command-center/
    governance-portal/
  services/
    api-gateway/   identity/   volunteers/   donations/   events/
    crm/   communications/   ai-orchestrator/   approvals/   reporting/
  packages/
    ui/   contracts/   validation/   authorization/
  workers/
  database/
    migrations/   policies/
  infrastructure/
  tests/
  docs/
  .github/workflows/
```

10.5 Definition of done

- Code reviewed, merged and deployed to staging through the pipeline.

- Unit, integration and end-to-end tests written and passing; no new critical or high security findings.
- Accessibility checks passed for new screens.
- Audit events and permissions implemented and tested for the feature.
- Documentation and runbook entries updated; acceptance criteria demonstrated to the product owner.

11. Phase-by-Phase Development Plan and Design

The plan spans 20 weeks, from October 26, 2026 to March 12, 2027. Dates are proposed and depend on timely approvals. Each milestone requires documented acceptance before the next phase is released. The Phase 3 window includes the end-of-year holidays, so reviewer availability should be confirmed early.

11.1 Schedule overview

Workstream	P0 Oct 26-Nov 6	P1 Nov 9-27	P2 Nov 30-Dec 18	P3 Dec 21-Jan 15	P4 Jan 18-Feb 12	P5 Feb 15-Mar 12
Audit and discovery	■					
Architecture and security design	■	■				
Identity, MFA, CI/CD, database		■				
Public website and CMS			■			■
Community, volunteers, events				■		
Donations, payments, CRM				■		■
Staff Command Center				■	■	
Governance portal					■	■
AI agents and orchestration					■	■
Testing, security, accessibility		■	■	■	■	■
Training, recovery drills, launch						■

Shaded cells show the phases in which each workstream is active.

Phase	Dates	Duration	Milestone
0 Audit and Discovery	Oct 26 - Nov 6, 2026	2 weeks	M0: Architecture approved
1 Secure Foundation	Nov 9 - Nov 27, 2026	3 weeks	M1: Security baseline passes
2 Website Modernization	Nov 30 - Dec 18, 2026	3 weeks	M2: Content and UX approved
3 Community and Donations	Dec 21, 2026 - Jan 15, 2027	4 weeks	M3: Payment and workflow tests pass
4 AI Workforce	Jan 18 - Feb 12, 2027	4 weeks	M4: Agent evaluations pass
5 Integration and Launch	Feb 15 - Mar 12, 2027	4 weeks	M5: Final production sign-off

11.2 Phase 0: Audit and Discovery (Oct 26 - Nov 6, 2026)

Objective	Establish facts about the current site, data, risks and requirements, and decide the final architecture path.
Key activities	CMS and hosting audit: WordPress core, theme, plugins (including Slider Revolution), PHP version, backups, performance, accessibility and security scan. Content inventory and URL map; ownership of domain, hosting, PayPal account, social accounts and content confirmed. Data inventory: forms, mailing lists, donor and volunteer data, where it lives and who can see it. Stakeholder workshops: executive, program, finance, volunteer coordination, communications, safeguarding lead. Workflow mapping of workflows A to F and the restricted intake route as they operate today. Threat model and privacy impact assessment; legal review scope agreed with counsel. Decision on Option A (retain and harden WordPress) or Option B (Next.js rebuild).
Design outputs	Architecture decision record, system context and data-flow diagrams, role matrix, requirements backlog, risk register, detailed phase plan.
Exit criteria (M0)	Architecture and security approach approved by the owner and safeguarding lead; CMS decision recorded (Gate G0); environments and access agreed.
Main risks	Unknown plugin or hosting issues; unclear data ownership; limited staff time for workshops.

11.3 Phase 1: Secure Foundation (Nov 9 - Nov 27, 2026)

Objective	Build the platform base that every later feature depends on.
Key activities	Create repositories, branching rules, CI/CD pipeline and infrastructure as code. Stand up development, staging and production environments; set up CDN, WAF, secrets management and logging. Implement identity: OIDC provider, MFA, role model, session policy, administrator hardening. Create the PostgreSQL schema baseline, migrations framework and row-level security policies. Build the API gateway, shared contract package, audit service and notification service skeletons. Prepare the isolated environment for the restricted boundary (accounts, network, keys) without any live data. Build the design system foundation and accessibility tooling.
Design outputs	Environment diagrams, database schema v1, authorization policy matrix, API standards, design tokens and core components.
Exit criteria (M1)	Security baseline passes: MFA and role tests, secrets and encryption checks, no critical or high findings, backups verified.
Main risks	Identity integration complexity; delays in provider accounts or DNS access.

11.4 Phase 2: Website Modernization (Nov 30 - Dec 18, 2026)

Objective	Deliver the improved public website without disrupting giving or support access.
Key activities	Implement the new information architecture, templates and navigation (Section 4). Migrate and edit approved content; keep existing URLs or add 301 redirects; publish accessible Impact Report page. Build forms (contact, volunteer interest, event registration interest) writing to validated intake queues. Implement Get Help hub with Safe Exit and the safe routing hand-off to the restricted endpoint. Set up editorial workflow (draft, review, publish) and editor training materials. Mobile, performance and SEO optimization; multilingual framework in place; accessibility remediation to WCAG 2.2 AA. Keep the PayPal donation link live and verify it on every release.
Design outputs	Final sitemap, wireframes and visual design, content model, form specifications, redirect map.
Exit criteria (M2)	Content and UX approved by the owner; accessibility checks pass; Safe Exit and sensitive-page privacy behaviours verified; redirects tested.
Main risks	Content approval delays; consent for imagery and stories; plugin conflicts if WordPress is retained.

11.5 Phase 3: Community and Donations (Dec 21, 2026 - Jan 15, 2027)

Objective	Deliver the volunteer, donor, CRM and events capabilities with verified financial integrity.
Key activities	Community and Volunteer Hub: applications, tracking IDs, screening queue, orientation and training, hours and feedback (Workflow B). Events and programs: creation, approval, registration, capacity and waitlists, check-in, feedback (Workflow D). CRM: organizations, contacts, interactions, partnerships; shared inbox integration. Donations: hosted checkout, recurring giving, signed webhooks, idempotent ledger, receipts, reconciliation views (Workflow C). Donor and Sponsor Portal: history, receipts, sponsorship and downloadable records. Staff Command Center core: queues, tasks, calendars, approval inbox. Run parallel reconciliation of new ledger against the existing PayPal pathway before any switch-over.
Design outputs	Service contracts, state machines for applications and registrations, ledger design, reconciliation reports, role-based screen designs.
Exit criteria (M3)	Payment records reconcile to provider transactions; zero unauthorized financial actions in tests; capacity can never be exceeded; workflow tests pass.
Main risks	Holiday-period availability; payment-provider onboarding lead time; data migration quality.

11.6 Phase 4: AI Workforce (Jan 18 - Feb 12, 2027)

Objective	Introduce the 18 agents safely, in simulation first, behind the policy gateway.
Key activities	Build the AI Command Center: agent registry, permissions, usage limits, monitoring dashboard and disable controls. Implement the Policy and Approval Gateway with tool allowlists, role checks, approval tasks and audit trails. Define each agent (A01 to A18): instructions, tools, data scope, escalation rules and test dataset. Implement email and calendar assistance with staff approval (Workflow A) and grants and board support (Workflow F). Create the curated public knowledge base for the Website Concierge. Run evaluation suites, including prompt-injection, leakage and approval-bypass tests; fix and re-run. Governance Portal: executive summaries, approval register, board documents and oversight dashboards.
Design outputs	Agent specification sheets, policy rules, evaluation reports, approval-queue interface designs, governance dashboard designs.
Exit criteria (M4)	Agent evaluations pass; email and calendar approval workflows pass; no agent can act without approval where required; safeguarding lead reviews sensitive-path agents.
Main risks	Model behaviour drift; over-reliance on automation; staff capacity to review drafts.

11.7 Phase 5: Integration and Launch (Feb 15 - Mar 12, 2027)

Objective	Prove the whole system works together, train people, rehearse recovery and release in controlled stages.
Key activities	End-to-end testing across all five applications and shared services; performance and load testing. Independent penetration test and adversarial tests against the restricted boundary; remediation. Restricted workflow (E) walkthrough and sign-off by the safeguarding lead before activation. User acceptance testing with staff, volunteers and board representatives. Backup restoration, failover and rollback drills. Staff training, quick-reference guides and operating procedures; support and escalation contacts. Staged production deployment: internal users, then pilot users, then public; monitored hypercare period. Switch donation pathway only after final reconciliation pass; retain fallback link.
Design outputs	Runbooks, release plan, rollback plan, training materials, operating procedures, hypercare plan.
Exit criteria (M5)	All 12 release gates in Section 13 confirmed; safeguarding lead sign-off; authorized executive approves production release.
Main risks	Late-found defects; training time; cutover timing around fundraising activity.

12. Migration, Cutover and Rollback Plan

Stream	Approach	Safeguard
Content	Inventory, edit, approve, then migrate; keep a content freeze window of a few days before launch.	Original site retained read-only until post-launch review.
URLs and SEO	Redirect map from old to new URLs; sitemap and canonical tags updated; search console monitored.	Redirect tests in staging; broken-link monitoring after launch.
Donations	New checkout built and tested in parallel; ledger reconciled with existing provider records.	PayPal pathway remains available until reconciliation is passed; instant fallback link.
Data (volunteers, donors, contacts)	Clean, de-duplicate and import with mapping reports; sensitive categories reviewed before import.	Dry runs on anonymized data; import is repeatable and reversible.
Email and calendar	Connect shared mailboxes and calendars in read-only mode first, then enable write actions.	Per-mailbox enablement; staff can disconnect at any time.
AI agents	Simulation, then shadow mode, then supervised production, one agent at a time.	Global and per-agent disable switches.
Restricted services	Activated only after safeguarding lead sign-off, in its own environment.	No data migration into or out of the general platform.

12.1 Rollback triggers

- Any confirmed incorrect or missing donation record not resolved within an agreed window.
- Any confirmed unauthorized access to restricted or confidential data.
- Critical accessibility or availability failure on the public site or Get Help pages.
- Failure of health checks or error-rate thresholds after deployment.

Rollback means restoring the previous release and database snapshot using the rehearsed procedure and re-pointing traffic; the retained original site and PayPal pathway ensure public giving and help routes are not interrupted.

13. Quality Assurance and Production Readiness

13.1 Test strategy

Test type	Scope	When
Unit and component	Business rules, validators, UI components	Every commit
Integration	Service-to-service, database, payment sandbox, email and calendar	Every merge to main
End-to-end	Full workflows A to F on staging with synthetic data	Nightly and before each release
Security	Dependency, secret and static analysis; authenticated scans; penetration test	CI and before launch
Authorization	Role matrix tests; adversarial attempts to reach restricted records	Every release
Accessibility	Automated checks, keyboard and screen-reader review	Every sprint and before launch
Performance	Load, mobile network profiles, database query review	Phase 2 and Phase 5
AI evaluation	Accuracy, refusal, injection, leakage, approval-bypass	Every agent change
Recovery	Backup restore, failover, rollback drills	Before launch and quarterly
User acceptance	Staff, volunteers and board representatives on staging	End of each phase

13.2 Production readiness checklist

All items are release gates, not optional enhancements. Each must be confirmed with evidence before milestone M5.

#	Release gate	Evidence	Confirmed
1	MFA and role-based access tests pass		[ ]
2	No unresolved critical or high security vulnerabilities		[ ]
3	Zero successful unauthorized financial actions in test scenarios		[ ]
4	Zero successful restricted-record disclosures in adversarial tests		[ ]
5	AI email and calendar approval workflows pass		[ ]
6	Payment records reconcile with verified provider transactions		[ ]
7	Event registrations cannot exceed capacity		[ ]
8	WCAG 2.2 AA accessibility checks completed		[ ]

#	Release gate	Evidence	Confirmed
9	Backup restoration and rollback drills passed		[ ]
10	Staff training and operating procedures approved		[ ]
11	Safeguarding lead signs off restricted workflows		[ ]
12	Authorized executive approves production release		[ ]

14. Operations, Training and Support Model

14.1 Operating model after launch

- Monitoring dashboards and alerts for availability, errors, payment failures, queue depth and AI usage.
- Weekly review of security alerts and AI evaluation results for the first months; monthly thereafter.
- Quarterly access reviews and backup restoration tests; annual penetration test and disaster-recovery exercise.
- Documented on-call and escalation path, with a named owner for each application.
- Content calendar and editorial roles for the public site; translation review roster.

14.2 Training plan

Audience	Content	Format
Executives and board	Dashboards, approvals, governance portal, AI oversight	Live walkthrough and quick guide
Program and community staff	Volunteer queue, events, CRM, AI draft review	Hands-on workshops
Finance staff	Ledger, reconciliation, exceptions, receipts	Scenario-based session
Communications staff	CMS, editorial workflow, social queue, translation review	Hands-on workshop
Safeguarding-trained staff	Restricted environment, escalation, retention	Separate, confidential session led with the safeguarding lead
Volunteers and donors	Using their portals	Short guides and in-app help in key languages

15. Governance, Approval Gates, Risks and Decisions

15.1 Approval gates

Gate	Decision	Approver
G0	Retain/harden WordPress or rebuild public site	Owner (executive) with technical lead
G1	Architecture and security design approved (M0)	Owner and safeguarding lead
G2	Security baseline accepted (M1)	Owner and security reviewer
G3	Content and UX accepted (M2)	Owner and communications lead
G4	Payment and workflow tests accepted (M3)	Finance lead and owner
G5	Agent evaluations accepted (M4)	Owner; safeguarding lead for sensitive-path agents
G6	Restricted workflows activated	Safeguarding lead
G7	Production release (M5)	Authorized executive

15.2 Responsibility matrix (summary)

Activity	Phumulani owner	Safeguarding lead	Finance lead	Ophireum team
Requirements and priorities	A	C	C	R
Architecture and security design	A	C	C	R
Content approval	A	C	I	R
Payment design and reconciliation	C	I	A	R
AI agent policies and evaluations	A	C	C	R
Restricted workflow design and activation	C	A	I	R
Testing and defect fixing	I	C	C	A/R
Training and launch	A	C	C	R

A = accountable, R = responsible, C = consulted, I = informed.

15.3 Key risks and mitigations

Risk	Impact	Mitigation
Exposure of survivor information	Severe harm to people and trust	Isolated boundary, minimal data, adversarial tests, safeguarding sign-off, no general AI access

Risk	Impact	Mitigation
AI produces incorrect or inappropriate output	Reputational harm; wrong decisions	Human approval gates, evaluations, shadow mode, disable controls
Donation errors during cutover	Lost revenue; donor trust	Parallel running, reconciliation tests, fallback link
Legacy website vulnerabilities	Defacement or data loss	Early audit, patching, WAF, backups
Staff capacity and change fatigue	Slow adoption	Phased rollout, training, simple interfaces
Schedule slippage (approvals, holidays)	Delayed milestones	Early scheduling of reviewers, phase gates, prioritized backlog
Vendor or API changes	Integration failure	Adapters, contract tests, monitoring
Accessibility or language gaps	Excludes community members	WCAG gates, multilingual review, plain language

15.4 Immediate next decisions

1. Authorize Phase 0 (Audit and Discovery) to start on October 26, 2026.
2. Name the Phumulani owner, safeguarding lead and finance lead for approvals.
3. Provide access for the audit: hosting, WordPress administration, analytics, payment account and domain registrar.
4. Agree the Gate G0 decision date: retain and harden WordPress, or rebuild on Next.js.
5. Engage counsel for the Minnesota and federal privacy and confidentiality review.

> **Governing rule**
> AI assists Phumulani's people; it does not replace human judgment in safeguarding, financial authorization, volunteer screening or organizational governance.

Appendix A: Glossary

Term	Meaning
API gateway	Single entry point that authenticates, validates and routes requests to services
CMS	Content management system used to edit the public website
CRM	Customer or constituent relationship management for contacts and interactions
Idempotency	Design that makes repeating the same request safe, with no duplicate effect
MFA	Multi-factor authentication
OIDC	OpenID Connect, a standard for single sign-on
RBAC	Role-based access control
Row-level security	Database feature restricting which rows a user or service can read or change
Safe Exit	Control that quickly leaves a sensitive page for a neutral site
Shadow mode	AI outputs shown to staff for evaluation without any action being taken
WAF	Web application firewall
WCAG 2.2 AA	Web Content Accessibility Guidelines, version 2.2, conformance level AA

Appendix B: Milestone Acceptance Template

Milestone	M_ (name)
Phase and dates	
Deliverables reviewed	
Tests and evidence attached	
Open defects (severity and plan)	
Risks raised	
Decision	Accepted / Accepted with conditions / Not accepted
Approver name, role, date	